SYSTEMS ARCHITECTURE · AUDIT REPORT

Teafairweb and Web Consoles — Audit and Design Specification

The public retail storefront, the tenant operations console and settlement governance, with Monvelo oversight kept in its own domain.

DOCUMENT	VERSION	DATE	CLASSIFICATION
TF-RPT-WEB-001	**1.0**	**2026-11-03**	**Internal — Confidential**

SCOPE OF THIS DOCUMENT

Audits the web-facing backend at migration 20261031121300: public gateways, routing, pricing, NAFDAC, stock, fulfilment, the Paystack money loop and commission release.

Applies A6 §15: web never touches Monvelo. Lender oversight is specified as a separate console.

32
Edge Functions

11
scheduled jobs

110
migrations read

Contents

1. Executive Summary 4

1.1 Key audit findings 4

2. Audit Baseline and Method 6

2.1 Audit baseline 6

2.2 Rules every client inherits (Spec A §9) 6

2.3 Public gateway rules (A1, D1, A3, A5) 7

2.4 Error contract 7

3. Storefront and Public Routing 9

3.1 Proposed stack (needs owner confirmation) 9

3.2 Codeless and coded storefronts 9

3.3 Location: routing and the fare, not pricing 10

3.4 NAFDAC compliance badges 10

3.5 Checkout flow 10

3.6 Break-bulk and wholesale: not on the storefront 11

4. Tenant and Brand Operations Console 12

4.1 Isolation model 12

4.2 Contact reports (the source of truth) 12

4.3 Catalogue and brand operations (Purerigin and beyond) 12

4.4 Inventory and stock movements 13

4.5 Fulfilment of web orders 13

5. Settlement Governance (Web Money) 14

5.1 Scheduled jobs 14

5.2 Paystack webhook and settlement 14

5.3 Commission release 15

5.4 Console views 15

6. Monvelo Console (Separate Domain) 17

6.1 Liquidity health (proposal) 17

6.2 One agent's exposure: get_monvelo_agent_exposure 18

7. Design System and Quality Bar 20

8. Audit Findings and Gaps 21

9. Appendix A — Web RPC Contracts 22

9.1 Storefront (service_role, behind public gateways) 22

9.2 Tenant console 22

9.3 Fulfilment 23

9.4 Settlement (system) 23

9.5 Monvelo console 23
10. Appendix B — Enumerations and Statuses 25
10.1 Enumerations and status sets 25
10.2 Gateways in the repository 25

SECTION 1

Executive Summary

Teafairweb (teafairweb.com) is Teafair's public retail storefront. It is hosted on Vercel in its own repository (A1) and sells to consumers at full retail price, with WhatsApp-verified checkout through Paystack. This document audits the backend contracts the web depends on and specifies three web surfaces: the storefront, a tenant operations console, and the settlement governance views. Monvelo oversight is covered too, with one structural correction.

STRUCTURAL CORRECTION: THREE SURFACES, TWO DOMAINS

The brief placed **lender capital tracking and liquidity health** inside the Teafairweb portal. That would break a binding ruling. **A6 §15 (owner, 2026-10-28): Monvelo is strictly B2B trade financing and web never touches it.** A guard test (045) fails the build if any function names both a web_ and a monvelo_ table. §16.2.2 adds that **tenants never see or steer lenders**.

Resolution: the Monvelo oversight views are specified here (Section 6) as a separate **Monvelo console**: its own app or route group, signed in with the platform roles MONVELO_OPERATOR and MONVELO_FINANCE, sharing no code path with the storefront or the tenant console beyond the design system.

Surface	Users	Auth	Backend path
Teafairweb storefront	anonymous consumers	none; Turnstile and a WhatsApp phone check at checkout	public gateways → service_role RPCs
Tenant operations console	ZSM, TM, CSM, LOGISTICS_MANAGER, TENANT_ADMIN (read-only), warehouse staff	Supabase Auth session, active tenant in the JWT	PostgREST rpc() and user gateways with the user's JWT
Monvelo console	MONVELO_OPERATOR, MONVELO_FINANCE; PLATFORM_SUPER_ADMIN	Supabase Auth, platform role checked live	monvelo_* RPCs only

Table 1. Web surfaces and their trust boundaries.

1.1 Key audit findings

#	The brief expected	The schema does	Resolution
W1	Location-based pricing from commerce_ng_locations.	20261020120000_commerce_ng_locations is a migration file. It creates ng_states and ng_lgas (the 37 states and their LGAs). Location decides deliverability and routing, never the price. Prices are the product's retail unit_price, plus a flat per-tenant transport fare.	Specified as LGA routing + a flat fare (§3.3).

#	The brief expected	The schema does	Resolution
W2	Break-bulk pricing and wholesale tiers on the web.	Web sales are retail, single units, no discounts (owner, 2026-10-24). Break-bulk applies only to app (trade) sales.	The console edits pack data in the catalogue; the storefront never shows it.
W3	Purerigin coconut and palm oil dashboards.	Only Purerigin Coconut Oil (200 ml, 100 ml) is in the schema. No palm-oil product exists.	Dashboards are catalogue-driven; palm oil appears once a CSM loads it citing a CATALOGUE decision.
W4	Lender capital and liquidity health in the web portal.	Monvelo is a separate domain (A6 §15); tenants never see lenders (§16.2.2).	Moved to the Monvelo console (Section 6).
W5	Admin review of commission disputes.	Commissions move to DISPUTED automatically and ZSMs are notified. Resolving a dispute is D3, which is not built. Refunds are started in the Paystack dashboard.	Console shows and explains; actions wait for D3.
W6	Next.js on Vercel.	Vercel is in A1. No spec fixes the framework. Next.js is a sound fit, but it is the brief's choice, not a recorded decision.	Recorded as a proposal for the owner to confirm.

Table 2. Brief versus schema.

SECTION 2

Audit Baseline and Method

2.1 Audit baseline

This document was generated on 2026-11-03 directly from the repository's local migrations. Every function signature, EXECUTE grant, enum value, status set and cron job quoted in the appendices is parsed from supabase/migrations at build time, so the document and the schema cannot drift apart silently: re-running the generator re-reads them.

Item	Value
Migrations read	110 files, 20261006120000 → 20261031121300
Latest migration	20261031121300_monvelo_field_agents_decide_holds.sql
Public SQL functions	238 (latest definitions), of which 113 are executable by authenticated
pgTAP coverage	3,650 assertions in 66 files
Edge Functions	32 gateways in supabase/functions
Scheduled jobs (pg_cron)	11 active jobs
Governing documents	Spec A (2026-10-05) and addenda A1–A6, including A6 §19.4 and §20 (2026-11-02)
Deployment state	The remote project holds the 29 migrations to 20261015130200 (A1, A2). Everything after, including all of Monvelo, is built and tested locally and is not pushed.
Audience	Teafairweb engineers, console engineers, finance and operations leads, Spec B and D3 authors.

2.2 Rules every client inherits (Spec A §9)

These rules are enforced in the database and the gateways. A client cannot weaken them; it can only fail to respect them and receive an error. Each one shapes a front-end decision.

Rule	What the client must do
No direct client writes. authenticated has SELECT only; every mutation is a SECURITY DEFINER RPC.	Never call .insert(), .update() or .delete() through supabase-js. Every write is rpc() or a gateway POST.
The tenant comes from the JWT, re-verified live against tenant_users.	Never send a tenant_id parameter. Switching tenant calls set_active_tenant and then refreshes the session so the access-token hook re-issues claims.
Gateways forward the caller's JWT, never the service-role key, for user work.	Send Authorization: Bearer <user JWT> to every /functions/v1/<name> call. No service key ever ships in an app or a browser bundle.

Rule	What the client must do
Every mutation takes p_idempotency_key uuid first, generated at enqueue time.	Generate the UUID when the user acts, store it with the queued mutation, and resend the same key on every retry.
Contact privacy: buyer contacts live only in order_contacts; bvn_nin_hash only in user_secure_profiles.	Never cache another person's phone or identity number on the device. Screens show what the RPC returns and nothing more.
Workflow statuses are text + CHECK; stable sets are enums.	Treat status strings as an open set in the UI: render unknown values with a neutral badge instead of crashing.
Money is NUMERIC(15,2), quantities NUMERIC(14,3), timestamps timestamptz.	Parse money as strings into a decimal type; never float arithmetic. Render times in Africa/Lagos from server timestamps.

Table 3. Database rules and their front-end consequences.

2.3 Public gateway rules (A1, D1, A3, A5)

- **Anonymous callers never touch PostgREST.** Public gateways call RPCs granted to service_role only, and resolve the tenant from the referral code, or TEAFAIR when there is none (codeless).
- **CORS** is limited to WEB_ALLOWED_ORIGINS. A request with no Origin (server-side rendering on Vercel) is served.
- **Turnstile** gates checkout, phone verification and ticket opening.
- **Client IP** is read only through _shared/commerce/client-ip.ts (cf-connecting-ip, else the first x-forwarded-for hop, and only if it parses as an IP literal). Which header to trust in production is a pre-deploy staging check (R19).

2.4 Error contract

RPC errors carry a SQLSTATE; gateways map them to HTTP. The client maps both to one of three behaviours: show and stop, retry, or re-authenticate.

SQLSTATE / HTTP	Meaning	Client behaviour
42501 / 403	Not allowed: wrong role, out of scope, not a member, the request's raiser deciding its own hold.	Show a neutral "not available to you" message. Do not retry. Refresh the role cache.
P0001 / 422	A business rule refused the action (the message is written for people, e.g. the exposure-cap sentence).	Show the server message verbatim. Move a queued entry to "Needs attention".
22023 (PostgREST 400)	Invalid parameter on a direct RPC (a reason under 10 characters, p_weeks outside 1–52, p_allow null). Not in the gateway contract.	Validate on the client first so this is rare; show the message beside the field.
23505 / 409	Conflict (e.g. a duplicate the database refuses).	Show and stop; refresh the affected list.
TF001 / 409	Insufficient stock; details carry {sku_code, available, requested}.	Offer to reduce the quantity to available.

SQLSTATE / HTTP	Meaning	Client behaviour
TF002 / 409	Idempotency key reused with a different payload.	Terminal. Never generate a new key silently for the same user action.
40001, 55P03 / 503; network failure	Transient (serialisation, lock timeout, no signal).	Retry with exponential backoff, 2 s to 5 min, same idempotency key.
PGRST301 / 401	Session expired between the gateway check and the RPC.	Refresh the session once; on failure, return to sign-in and keep the queue.

Table 4. Error mapping (Spec A §3.5, §7.3; supabase/functions/_shared/core/errors.ts).

SECTION 3

Storefront and Public Routing

3.1 Proposed stack (needs owner confirmation)

Concern	Proposal	Why
Framework	Next.js (App Router) on Vercel	SSR for catalogue SEO; route handlers can proxy to gateways server-side; Vercel is already the host (A1).
Data	Server Components fetch storefront-catalogue and storefront-locations with no Origin; the CDN caches by the gateway headers	The gateways already send Cache-Control (catalogue max-age=60, s-maxage=300; locations max-age=3600).
Styling	Tailwind with the teafair-* tokens (FIGMA.md)	The same tokens as the app; never stock palette classes.
Secrets	None in the browser bundle. Only the public Turnstile site key and the gateway base URL, from env	.env stays gitignored; no Supabase key is needed for public gateways.

3.2 Codeless and coded storefronts

storefront-catalogue takes an optional code. **Codeless** (no code) sells TEAFAIR's catalogue directly. **Coded** (?code= from a referral link) resolves the tenant from web_referral_codes; a POS venue's code is how a POS agent earns a commission. The URL shape /?code=ABC123 must survive navigation and checkout (keep it in a first-party cookie for the session).

Gateway	Method	Purpose	Cache
`storefront-catalogue`	GET ?code=	Tenant, products, retail unit prices, NAFDAC fields, availability	max-age=60, s-maxage=300
`storefront-locations`	GET ?code=	37 states with LGAs; deliverable per LGA for the resolved tenant	max-age=3600
`storefront-refund-policy`	GET	The active refund policy version and its text	5 min
`checkout-phone-verify-start / -confirm`	POST	Turnstile, then a WhatsApp code; returns the single-use verification token (30 min)	none
`web-checkout`	POST	Quote, initialise Paystack, place the order; replay returns the original URL	none
`web-order-status`	POST	Callback page status for a matching (public_reference, paystack_reference) pair	none
`support-ticket-open / -read / -message / -attachment`	POST	Buyer support with a (public_reference, secret) capability	none

Table 5. Public gateways the storefront calls.

3.3 Location: routing and the fare, not pricing

- **LGA picker.** States, then LGAs, from storefront-locations. Undeliverable LGAs are shown greyed out with "We don't deliver here yet", not hidden, so a buyer understands why.
- **`lga_id` is required on every checkout** (D1). The database routes the order to the territory covering the LGA (else the state), its warehouse, and an accountable person (the TM, else the ZSM, else web_default_agent_id). No territory, warehouse or person is ever named to the buyer.
- **Price** is the product's retail unit_price, the same in every LGA. **The transport fare** is a flat amount per order from tenant_settings.web_transport_fare (TEAFAIR ₦750, others ₦0), shown as its own line.
- **No discounts.** Web discounts are switched off by trigger, and the quote's discount is always 0. The UI must not render a discount field or a promo-code box.

The cart quote

quote_web_order(p_code text, p_items jsonb, p_lga_id uuid) (service_role, called by the gateway) returns subtotal, discount (0), goods_total, transport_fare and total (goods plus fare). The page shows exactly these values; it never recomputes the total in the browser. place_web_order receives p_expected_total, so a stale cart is refused rather than charged.

3.4 NAFDAC compliance badges

Rule	Storefront behaviour
central_products.nafdac_number: upper-case letters and digits in 2–6 hyphenated groups, at most 32 characters (LG-IKJ-02-2134)	Render "NAFDAC Reg. No. LG-IKJ-02-2134" on the product card and page, with a link to the regulator's public lookup.
An active FOOD or COSMETICS product must have one (CHECK central_products_nafdac_required, NOT VALID for legacy rows)	If a legacy product arrives without a number, show no badge and never invent one; the console lists such products (§4.3).
Sale categories per tenant (tenant_allowed_categories); TELECOM is Sureach's alone (NCC licence)	Category chips come from the catalogue; never hard-code a category list.
Refund policy v2.0-food-cosmetics (placeholder text, legal review pending)	Show the category's refund copy on the product page and require the consent checkbox at checkout (accept_refund_policy, policy_version_tag).

Table 6. Regulatory display rules.

3.5 Checkout flow

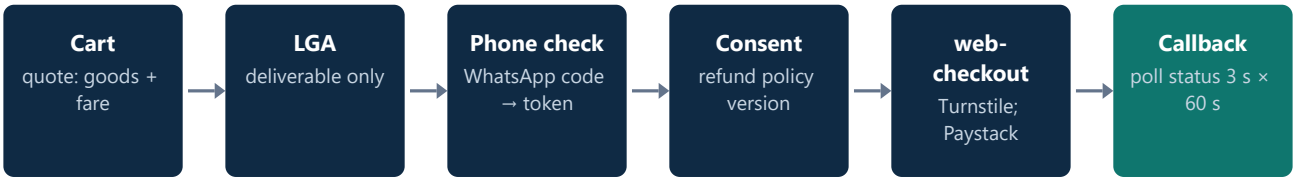


Figure 1. Retail checkout (A1, D1, A5).

- **Idempotency:** the checkout page generates one key per attempt and keeps it in sessionStorage, so a refresh replays and returns the same Paystack URL.

- **Callback page:** Paystack appends reference. Call web-order-status with both references every 3 s for up to 60 s while PENDING, then show "Your payment is being confirmed — keep your reference TF-XXXXXX". The 5-minute sweep completes the rest.
- **After delivery:** the buyer gets the delivery code by WhatsApp and reads it to the rider. Damage must be reported within 24 hours, with photos, through a support ticket.

3.6 Break-bulk and wholesale: not on the storefront

Trade buyers order through ZSAs and ASAs in the app, in whole packs at wholesale (see the mobile specification). The storefront sells single units at retail. Pack sizes (carton_units, break_bulk_units) and wholesale prices appear only in the tenant console's catalogue editor.

SECTION 4

Tenant and Brand Operations Console

4.1 Isolation model

- **One session, one active tenant.** The console reads active_tenant_id from the JWT and switches with set_active_tenant, then refreshes the session. It never passes a tenant id to an RPC (the only exceptions are platform-admin calls such as appoint_zone_manager).
- **Reads** go through RLS FOR SELECT policies and my_*_ids() helpers. A ZSM sees the zones they cover (§18.3). TENANT_ADMIN is read-only: every write RPC refuses it with 42501, so the console hides write controls for that role and still handles the 42501.
- **Writes that change a tenant agreement cite a contact-report decision** ("zero backdoors", A6 §16): catalogue (CATALOGUE), stock (STOCK), brand terms, settings and fees, and operational state (DISTRIBUTION). Every such form has a required "Decision" picker listing citable decisions: current, ZSM-reviewed and hard-copied.

4.2 Contact reports (the source of truth)

Step	Who	Call
File the report (attendees, decisions, recipients); corrections supersede	CSM	`file_contact_report(p_idempotency_key uuid, p_report jsonb)`
Review	ZSM (MONVELO_OPERATOR only while the tenant has no ACTIVE ZSM)	`review_contact_report(p_idempotency_key uuid, p_report_id uuid, p_outcome text, p_note text = null)`
Upload the signed hard copy (PDF/JPEG/PNG ≤ 10 MB)	CSM	`request_contact_report_hard_copy → gateway contact-report-upload → attach_contact_report_hard_copy`

4.3 Catalogue and brand operations (Purerigin and beyond)

upsert_catalogue_product(p_idempotency_key uuid, p_decision_id uuid, p_product jsonb) (CSM) creates or edits a product from a JSON object and must cite a CATALOGUE decision. The editor exposes sku_code, product_name, brand, category, sale_category, unit_price (retail), wholesale_price, carton_units, break_bulk_units (must divide the carton), nafdac_number and is_active. Generated pack prices are shown read-only.

Brand view (per brand of the active tenant)	Source
Retail web sales: orders, revenue (goods) and fares by day	orders (channel ONLINE) under the caller's RLS
Trade sales: whole-pack orders by area and ZSA/ASA	orders (FIELD_SALES), order_items
Stock on hand, reserved and available per warehouse and batch	inventory_batches (quantity_reserved is the stored sum), stock_reservations

Brand view (per brand of the active tenant)	Source
Monvelo-financed volume for the tenant's own lines (gross, fees; never the lender)	tenant ledger entries readable by the tenant
Products missing a NAFDAC number (legacy rows)	central_products where FOOD/COSMETICS and nafdac_number is null

Table 7. A brand dashboard is a filter over shared views. Purerigin Coconut Oil is the seeded example; no product is hard-coded.

4.4 Inventory and stock movements

Every movement is one insert-only stock_movements row: kind RECEIPT / TRANSFER / ADJUSTMENT / SALE_DISPATCH / ORDER_RETURN, warehouse, optional destination, SKU, batch, quantity (NUMERIC(14,3); positive except adjustments), reason, the decision cited and who recorded it. Dispatch writes SALE_DISPATCH consumption against reservations. Orders reserve stock at placement, first expiry first out.

Action	Role	Call
Receive	CSM or LM	`record_stock_receipt(p_idempotency_key uuid, p_decision_id uuid, p_warehouse_id uuid, p_sku_code text, p_batch_number text, p_quantity numeric, p_expires_at timestamptz)`
Transfer	CSM or LM	`record_stock_transfer(p_idempotency_key uuid, p_decision_id uuid, p_from_warehouse_id uuid, p_to_warehouse_id uuid, p_sku_code text, p_batch_number text, p_quantity numeric)`
Adjust (signed delta, reason required)	CSM or LM	`record_stock_adjustment(p_idempotency_key uuid, p_decision_id uuid, p_warehouse_id uuid, p_sku_code text, p_batch_number text, p_quantity_delta numeric, p_reason text)`
Return goods after dispatch (cites the order)	LM or CSM	`record_order_return(p_idempotency_key uuid, p_order_id uuid, p_lines jsonb)`

- **Movement ledger screen:** a filterable, append-only table (date, kind, SKU, batch, from → to, quantity, decision link, recorded by). There is no edit or delete; a correction is a new ADJUSTMENT.
- **Reservation sweep:** unpaid web orders are cancelled after tenant_settings.web_reservation_hours (24), and unpaid trade orders at the end of their Lagos supply day (stock-reservation-sweep, every 15 min). The console shows "reserved until" on each order.

4.5 Fulfilment of web orders

Step	Who	Gateway → RPC
Dispatch (generates the 4-digit delivery PIN, sends it to the buyer)	warehouse manager or ZSM	`order-dispatch → mark_order_dispatched`
Resend the PIN (3 a day)	same	`order-delivery-pin → resend_delivery_pin`
Delivery photo slot	deliverer	`order-delivery-photo`
Confirm delivery (5 wrong codes: 30-min lock; 10 lifetime: ZSM)	deliverer	`order-delivery-confirm → mark_order_delivered`

SECTION 5

Settlement Governance (Web Money)

Web money is collected by Paystack, settled by webhook and sweep, and split to POS partners' subaccounts when a referral code earns. No human approves a commission (Spec A decision 14); the console is for **oversight**, and its actions are limited to what the backend allows today.

5.1 Scheduled jobs

Job	Schedule (UTC)	Defined in
escalate-stale-pickups	*/15 * * * *	20261006130500_brand_tiers_and_escalation.sql
reconcile-funds-sweep	*/5 * * * *	20261020130300_fintech_liquidity_cron.sql
reconcile-funds-refunds	0 5 * * *	20261020130300_fintech_liquidity_cron.sql
close-resolved-support-tickets	30 0 * * *	20261021120200_support_staff_rpcs.sql
cleanup-web-phone-verifications	50 0 * * *	20261023120100_a5_checkout_consent.sql
cleanup-upload-slots	45 0 * * *	20261023120300_a5_upload_slots.sql
storage-purge	*/15 * * * *	20261023120310_a5_storage_purge_cron.sql
web-commission-release	0 6 * * *	20261028130500_web_commission_release_cron.sql
stock-reservation-sweep	*/15 * * * *	20261029130150_stock_reservations.sql
monvelo-offer-sweep	* * * * *	20261029130300_monvelo_claims.sql
monvelo-money-sweep	*/5 * * * *	20261031120400_monvelo_money_sweep.sql

Table 8. Active pg_cron jobs after every schedule and unschedule in the migrations.

> **HOW CRON REACHES THE GATEWAYS**
>
> pg_cron calls reconcile-funds and web-commission-release through pg_net (invoke_system_function). The base URL and the shared secret come from Vault (functions_base_url, cron_secret). Without them each run logs "functions_base_url or cron_secret is missing from Vault" and posts nothing. **The console's first health check is therefore: did each job post today?**

5.2 Paystack webhook and settlement

process-payment accepts charge.success and refund.processed. It checks the signature and a replay window, then re-verifies with Paystack before writing. References matching MV-... route to Monvelo (settle_monvelo_funding, apply_monvelo_refund); web references go to settle_paystack_payment, which settles at most once per (event, reference).

Verified status	< 2 h	2 h – 72 h	> 72 h
success	SUCCESS	SUCCESS	SUCCESS

Verified status	< 2 h	2 h – 72 h	> 72 h
failed, abandoned	not final	FAILED	FAILED
ongoing, pending, processing, queued	not final	not final	FAILED (audit SWEEP_EXPIRED)
reversed	full reversal via apply_paystack_refund		

Table 9. Status mapping (D1 §6.1). Exceptions write audit rows: PAYSTACK_MISMATCH, LATE_SUCCESS, PAID_AFTER_CANCEL.

5.3 Commission release

Step	Behaviour
Daily run (06:00 UTC)	web-commission-release lists subaccounts with SPLIT rows older than 24 h, pages Paystack List Settlements and Settlement Transactions, and calls release_commission per match.
Match	share × 100 equals the subaccount share → SETTLED; otherwise → DISPUTED with SETTLEMENT_MISMATCH. At most once per (settlement, payment).
Expiry	SPLIT older than 7 days → DISPUTED, NOT_SETTLED.
Refund	A full refund moves SPLIT or SETTLED → DISPUTED, ORDER_REFUNDED. Paystack does not claw the share back.
Notification	Every move to DISPUTED notifies the tenant's ZSMs (COMMISSION_DISPUTED) and raises a system ticket (A3).

RATES ARE ZERO TODAY

tenant_settings.web_agent_commission_bps is 0 for every tenant, TEAFAIR included, until the owner agrees rates (written by migration only). No order splits yet. The commission views will be empty until then, and the console should say so rather than show an error. The release path has been proven only against the integration fake, because Paystack test mode produces no real settlements (F6).

5.4 Console views

View	Content	Notes
Job health	Last run and outcome of each job; flags a missed day	Reads job audit rows (source CRON); cross-tenant job health is a platform view
Payments and webhook log	Payments by status, with the audit trail for each (SUCCESS, FAILED, LATE_SUCCESS, PAYSTACK_MISMATCH, PAID_AFTER_CANCEL, PARTIAL_REFUND, REFUND_CONFLICT)	payments is granted column by column; the console names columns and never select *
Commission ledger	SPLIT / SETTLED / DISPUTED with reason, subaccount, settlement id	Statuses from commission_status_enum

View	Content	Notes
Refunds	Refunds received (refund.processed, the daily refund pass), partial refunds flagged	Refunds are started in the Paystack dashboard; a staff refund gateway with a PIN is D3
Dispute evidence	Order header (goods total, discount, fare, total, referral code), lines with NAFDAC fields, payments with agent commission, delivery proof photos (signed 600 s)	order-dispute-evidence → get_order_dispute_evidence (ZSM); every view audited DISPUTE_EVIDENCE_VIEWED

Table 10. Settlement governance screens for ZSMs and finance.

SECTION 6

Monvelo Console (Separate Domain)

This is the brief's "system-wide liquidity health and lender capital tracking", placed where the rules allow it. It is a separate web application or route group, for platform roles only. It must not import storefront or tenant-console data code, mirroring guard test 045 on the backend.

Role	Sees (A6 §8)	Does
MONVELO_OPERATOR	all Monvelo tables	approves and suspends agents, sets caps (set_monvelo_agent_caps), records fee terms, reviews flags (review_monvelo_flag), reviews contact reports while a tenant has no ZSM
MONVELO_FINANCE	payables, payout accounts, tenant settlements, financings (read)	records rebate payouts and second approvals (Step 5, not built)

6.1 Liquidity health (proposal)

Metric	Definition	Backend source today
Capital deployed	Σ principal FUNDED + DELIVERED + DEFAULTED (open)	monvelo_financings (operator reads all)
Open exposure by agent	The §19.4 formula per agent; distribution against ₦1,000,000 and ₦3,000,000	get_monvelo_agent_exposure(p_agent_id) serves Monvelo staff one agent at a time (mobile G1, resolved 2026-11-03). A fleet-wide distribution still needs an operator list RPC.
Pledged vs used	Σ pledges.amount vs amount − remaining, by supply day and area	monvelo_pledges
Holds	HELD now; allowed, declined and lapsed rates; time to decision	monvelo_claim_holds has no policy. Needs an operator read RPC.
Refund exposure	REFUND_DUE count and principal; age of each	monvelo_financings, the refund tickets
Credit quality	Repaid within the window, repaid late, defaulted; PAR30 by raiser	monvelo_financings, monvelo_repayments
Flags	Open PAYER_MISMATCH, LATE_PAYMENT, AMOUNT_MISMATCH, REPAYMENT_REJECTED, REPAYMENT_UNCONFIRMED, FUNDING_REFUNDED	monvelo_flags
Unprovisioned agents	ACTIVE agents whose daily_cap or per_financing_cap is ₦0.00 or below the ₦1,000,000 ceiling	monvelo_agents (operator reads all); set with set_monvelo_agent_caps

Metric	Definition	Backend source today
Lender reconciliation	Weekly capital funded, outstanding, repaid, refunded, rebates per agent	get_lender_reconciliation_summary serves agents, ZSAs and ASAs only; operators need their own RPC (A6 §9 monvelo_finance_overview, not built)

Table 11. The A6 §9 finance dashboard RPCs (monvelo_finance_overview, monvelo_payables, monvelo_tenant_settlement_statement, monvelo_exceptions) are specified but not built.

6.2 One agent's exposure: get_monvelo_agent_exposure

get_monvelo_agent_exposure(p_agent_id uuid = null) (migration 20261031121200_get_monvelo_agent_exposure.sql, pgTAP 067) is read-only and granted to authenticated only. In the Monvelo console, staff name the agent; it returns one row:

Column	Type
agent_id	uuid
agent_status	text
open_exposure	numeric(15,2)
platform_ceiling	numeric(15,2)
allowance_ceiling	numeric(15,2)
remaining_room	numeric(15,2)
active_commitments_count	bigint
personal_daily_limit	numeric(15,2)
per_financing_limit	numeric(15,2)
today_utilized_limit	numeric(15,2)
today_remaining_limit	numeric(15,2)

- **Callers:** the agent's ACTIVE members and Monvelo staff (MONVELO_OPERATOR, MONVELO_FINANCE). Every tenant role (ZSM, ASA, ZSA, TM, CSM, TENANT_ADMIN) gets 42501 "Unauthorized access to agent exposure metrics", so the tenant operations console must never call it: a tenant never sees a lender (§16.2.2) and a market maker never sees the agent (§20.2 decision 3). Staff naming an unknown agent get no row.
- **Figures:** CLAIMED, HELD and FUNDED count their full principal, DELIVERED and DEFAULTED_WITH_LATE_CHARGE count least(outstanding, principal), and REFUND_DUE counts nothing (R63). The ceilings are read from the constants; personal_daily_limit and per_financing_limit are 0.00 until Monvelo staff set them (§21.2).

PROVISION AGENT CAPS AT ONBOARDING (A6 §21.2)

The platform ceiling is ₦1,000,000 and the market-maker allowance ₦3,000,000 (migration 20261031121100). An agent's daily_cap and per_financing_cap start at ₦0.00 and bind first.

The operator console must show unprovisioned agents and set their caps with set_monvelo_agent_caps. A market maker cannot override a personal cap (rule 3A); only the exposure ceiling can be allowed past.

SECTION 7

Design System and Quality Bar

Token	Hex	Web use
teafair-emerald	#4CAF50	Add to cart, Pay, primary console actions
teafair-lime	#8BC34A	Success states, the "Deliverable" chip
teafair-forest	#2E7D32	Header, footer, NAFDAC badge outline
teafair-black	#111111	Text
teafair-surface	#F5F7F6	Page and input backgrounds

Table 12. FIGMA.md tokens (locked 2026-10-07). The brand gradient runs 135° forest → emerald → lime.

- **Performance:** catalogue pages are server-rendered and CDN-cached. Product images are sized responsively. The aim is LCP under 2.5 s on a mid-range Android phone over 3G, the buyer's real device.
- **Accessibility:** WCAG 2.2 AA. Every status is shown with text as well as colour (deliverable, NAFDAC, commission status). Forms have labels; the code inputs use autocomplete="one-time-code".
- **Privacy:** no third-party trackers on checkout pages. Buyer phone and address go only to the gateways; the storefront never stores them beyond the session.
- **Observability:** gateway calls carry sentry-trace and baggage, so traces join the backend's Sentry spans (off unless SENTRY_DSN is set).

SECTION 8

Audit Findings and Gaps

ID	Severity	Finding	Recommendation
W-G1	High	The brief put lender tracking in the web portal, against A6 §15 and §16.2.2.	A separate Monvelo console (Section 6).
W-G2	High	The A6 §9 finance RPCs are not built, and there is no operator read path for exposure or holds.	A backend addendum before the Monvelo console.
W-G3	Medium	Commission dispute resolution and a staff refund gateway are D3 (not built).	The console is read-only on disputes until D3.
W-G4	Medium	Refund policy text is a placeholder pending legal review; versions are immutable (R20).	Counsel's text ships as a new version; the storefront reads whichever is active.
W-G5	Medium	The trusted client-IP header is unconfirmed (R19).	Run the staging check before launch.
W-G6	Low	The framework is not recorded in any spec.	Owner to confirm Next.js.
W-G7	Low	No palm-oil product exists.	Load it through upsert_catalogue_product with a CATALOGUE decision and a NAFDAC number.
W-G8	Info	Only A1/A2 are on the remote; D1 onwards is local.	Follow the deploy order in supabase/CLAUDE.md before launch.

Table 13. Findings ranked by severity.

SECTION 9

Appendix A — Web RPC Contracts

Signatures are the latest create or replace function in migration order. "Callers" are the roles holding EXECUTE after every grant and revoke. service_role means only a gateway can reach the function; authenticated means the app calls it with the user's JWT, and the function itself checks the role and scope live.

9.1 Storefront (service_role, behind public gateways)

Function	Callers	Returns
`storefront_catalogue(p_code text = NULL)`	service_role	jsonb
`quote_web_order(p_code text, p_items jsonb, p_lga_id uuid)`	service_role	jsonb
`place_web_order(p_idempotency_key uuid, p_code text, p_items jsonb, p_customer jsonb, p_utm jsonb, p_payment_route text, p_expected_total numeric, p_checkout jsonb, p_lga_id uuid, p_accepted_refund_policy boolean, p_policy_version_tag text, p_client_ip inet, p_phone_verification_token text)`	service_role	jsonb

9.2 Tenant console

Function	Callers	Returns
`set_active_tenant(p_idempotency_key uuid, p_tenant_id uuid)`	authenticated	jsonb
`upsert_catalogue_product(p_idempotency_key uuid, p_decision_id uuid, p_product jsonb)`	authenticated, service_role	jsonb
`record_stock_receipt(p_idempotency_key uuid, p_decision_id uuid, p_warehouse_id uuid, p_sku_code text, p_batch_number text, p_quantity numeric, p_expires_at timestamptz)`	authenticated, service_role	jsonb
`record_stock_transfer(p_idempotency_key uuid, p_decision_id uuid, p_from_warehouse_id uuid, p_to_warehouse_id uuid, p_sku_code text, p_batch_number text, p_quantity numeric)`	authenticated, service_role	jsonb
`record_stock_adjustment(p_idempotency_key uuid, p_decision_id uuid, p_warehouse_id uuid, p_sku_code text, p_batch_number text, p_quantity_delta numeric, p_reason text)`	authenticated, service_role	jsonb
`record_order_return(p_idempotency_key uuid, p_order_id uuid, p_lines jsonb)`	authenticated, service_role	jsonb
`file_contact_report(p_idempotency_key uuid, p_report jsonb)`	authenticated	jsonb
`review_contact_report(p_idempotency_key uuid, p_report_id uuid, p_outcome text, p_note text = null)`	authenticated	jsonb
`upsert_web_referral_code(p_idempotency_key uuid, p_code text, p_agent_id uuid, p_venue_id uuid, p_discount_type text, p_discount_value numeric, p_max_redemptions integer, p_expires_at timestamp with time zone, p_is_active boolean)`	authenticated, service_role	jsonb

Function	Callers	Returns
set_web_pos_venue(p_idempotency_key uuid, p_venue_id uuid, p_venue_channel venue_channel_enum, p_venue_name text, p_address_text text, p_state text, p_lga text, p_latitude double precision, p_longitude double precision, p_operating_hours jsonb)	authenticated, service_role	jsonb
set_territory_web_warehouse(p_idempotency_key uuid, p_territory_id uuid, p_warehouse_id uuid)	authenticated	jsonb
set_web_defaults(p_idempotency_key uuid, p_warehouse_id uuid, p_agent_id uuid)	authenticated	jsonb
set_territory_coverage(p_idempotency_key uuid, p_state_code text, p_lga_id uuid, p_territory_id uuid)	authenticated	jsonb

9.3 Fulfilment

Function	Callers	Returns
mark_order_dispatched(p_idempotency_key uuid, p_order_id uuid, p_tracking_reference text, p_pin text, p_gateway_proof text)	authenticated	jsonb
resend_delivery_pin(p_idempotency_key uuid, p_order_id uuid, p_pin text, p_gateway_proof text)	authenticated	jsonb
mark_order_delivered(p_idempotency_key uuid, p_order_id uuid, p_pin text, p_photo_attachment_id uuid = null)	authenticated	jsonb
get_order_dispute_evidence(p_order_id uuid)	authenticated	jsonb

9.4 Settlement (system)

Function	Callers	Returns
settle_paystack_payment(p_event text, p_reference text, p_status text, p_amount_minor bigint, p_currency text, p_verified jsonb, p_transaction_id text, p_split_subaccount text, p_split_share_minor bigint)	service_role	jsonb
apply_paystack_refund(p_source text, p_refund_id text, p_transaction_reference text, p_amount_minor bigint, p_currency text, p_reason text, p_verified jsonb)	service_role	jsonb
release_commission(p_settlement_id text, p_settled_at timestamp with time zone, p_reference text, p_subaccount_share_minor bigint)	service_role	jsonb

9.5 Monvelo console

Function	Callers	Returns
approve_monvelo_agent(p_idempotency_key uuid, p_agent_id uuid)	authenticated	jsonb
suspend_monvelo_agent(p_idempotency_key uuid, p_agent_id uuid, p_reason text)	authenticated	jsonb
set_monvelo_agent_caps(p_idempotency_key uuid, p_agent_id uuid, p_daily_cap numeric, p_per_financing_cap numeric)	authenticated	jsonb
record_monvelo_fee_terms(p_idempotency_key uuid, p_tenant_id uuid, p_fee_bps integer, p_valid_from date, p_valid_to date, p_decision_id uuid)	authenticated, service_role	jsonb

Function	Callers	Returns
`review_monvelo_flag(p_idempotency_key uuid, p_flag_id uuid, p_note text)`	authenticated	jsonb

SECTION 10

Appendix B — Enumerations and Statuses

10.1 Enumerations and status sets

Name	Values (in definition order)
order_channel_enum	ONLINE, FIELD_SALES, RETAIL
payment_status_enum	INITIATED, PROCESSING, SUCCESS, FAILED, REFUNDED
commission_status_enum	SPLIT, SETTLED, DISPUTED
gateway_provider_enum	PAYSTACK
pos_network_enum	MONIEPOINT, OPAY, PALMPAY
warehouse_kind_enum	CENTRAL, REGIONAL, STOCKIST
venue_channel_enum	CHURCH, MOSQUE, HOSPITAL, OFFICE_COMPLEX, RESIDENTIAL_ESTATE, EDUCATIONAL_INSTITUTION, EVENT_CENTER, TRANSIT_HUB, OPEN_MARKET, OTHER
audit_source_enum	USER, SYSTEM, WEBHOOK, CRON, WEB
orders.status (CHECK)	PENDING, PAID, IN_TRANSIT, DELIVERED, CANCELLED, REFUNDED
stock_movements.kind (CHECK)	RECEIPT, TRANSFER, ADJUSTMENT, SALE_DISPATCH, ORDER_RETURN

10.2 Gateways in the repository

auth-verify-claims · checkout-phone-verify-confirm · checkout-phone-verify-start · contact-report-upload · monvelo-agent-register · monvelo-confirm-delivery · monvelo-confirm-repayment · monvelo-fund · monvelo-shop-consent · order-delivery-confirm · order-delivery-photo · order-delivery-pin · order-dispatch · order-dispute-evidence · otp-issue · otp-verify · process-payment · reconcile-funds · send-auth-email · send-auth-sms · storage-purge · storefront-catalogue · storefront-locations · storefront-refund-policy · support-staff-attachment · support-ticket-attachment · support-ticket-message · support-ticket-open · support-ticket-read · web-checkout · web-commission-release · web-order-status